



Swiftdigital

**Swiftdigital Web & API
VAPT 2026**

May 08, 2026

8

Table of Contents

Confidentiality and Distribution Restrictions

The conclusions and recommendations in this report represent the opinions of Securify. Determinations of appropriate corrective action(s) are the responsibility of the entity receiving the report. This report and/or any other materials furnished by Securify in connection with this engagement is confidential and may not be duplicated, modified or otherwise reproduced and distributed without the express prior written consent of Securify or Swiftdigital. Because this work may contain copyrighted images or other material, permission from the copyright holder may also be necessary if you wish to reproduce.

Introduction

As part of an ongoing security program, Swiftdigital identified the need to conduct an application security assessment of its Web application & APIs.

This report presents the agreed scope, methodology, risk measurement model, summarized findings, and detailed technical observations for the selected assessment window.

The following lists the objectives of this assessment:

- Determine the overall security posture of the application
- Provide a list of key findings and recommendations for remediation
- Document the assessment scope, risk evaluation, and final outcomes
- Support remediation planning with actionable technical detail

This report includes the following parameters and results of the assessment:

Approach

Securify performed a Runtime Application Vulnerability Assessment of the client environment using a combination of manual testing, guided analysis, and targeted verification of identified attack paths.

Testing focused on authentication, authorization, business logic, session management, input handling, information disclosure, and transport-layer protections.

Where appropriate, the assessment also included abuse-case validation, access-control bypass attempts, forced browsing, parameter tampering, and endpoint enumeration.

Runtime Application Vulnerability Assessment

The runtime assessment focused on security behavior observable in the live application and API flows, including authentication, authorization, input handling, business logic, sensitive data exposure, and common attack-surface weaknesses.

The engagement emphasized practical exploitability and realistic attacker behavior rather than purely theoretical weaknesses.

- **Information Gathering** — The application was reviewed as an anonymous, authenticated, and privileged user to understand differences in access and behavior. Technologies, frameworks, APIs, and third-party integrations were also identified to support targeted testing.
- **Authentication Testing** — Authentication mechanisms were evaluated to determine the strength of login controls, password policies, and account recovery processes. Protections against brute-force attempts and session takeover scenarios were also reviewed to ensure users are securely authenticated.
- **Authorization Testing** — Tests were conducted to identify weaknesses in access control, including attempts to access other users' data or privileged functionality.
- **Session Management** — Session handling was assessed to ensure secure creation, storage, and invalidation of session tokens.
- **Input Validation Attacks** — User-controlled input fields were tested with malformed and malicious data to identify injection flaws and logic bypasses. This included attempts to trigger unexpected behavior, access unintended functionality, or exploit vulnerabilities such as XSS, SQL injection, and command injection.
- **Business Logic Testing** — The application's workflows were reviewed to identify opportunities to misuse or bypass intended processes. This included testing for logic errors, insufficient validation, and scenarios where typical constraints could be circumvented.

Scope

The assessment was conducted between Start Date and End Date. The scope of the assessment was limited to the environments and targets below:

Application Details

Name	URL
swiftdigital	https://swiftdigitalservices.com

User Roles (Web application & API)

Role	Username
Administrator	swiftdigitalh@gmail.com
Administrator	swiftdigitald@gmail.com

The following components and tests were out of scope for this review:

- Any applications and infrastructure external to the Swiftdigital's Web Application & API.
- In cases where the Swiftdigital's Web Application & API had inbound and/or outbound interfaces with:
- Another application, the interfaces, and communications were considered in scope.
- All other external elements were excluded.
- Supporting policies, procedures, and processes.
- Social Engineering.
- Software Development Life Cycle.

Assessment Limitation

This assessment was performed within the agreed timebox and only against systems explicitly included in scope. Absence of identified vulnerabilities should not be interpreted as a guarantee that no issues remain.

Findings and Recommendation

The sections below summarize the observed risks and provide the measurement criteria used to classify findings across the engagement.

Each finding is evaluated using the same impact and likelihood model so remediation can be prioritized consistently.

Risk Classification

Risk is determined by evaluating the combined effect of impact and likelihood for each issue identified during testing. The matrix below is used as the standard model for determining overall severity.

Measurement of Impact

Impact reflects the potential business, technical, operational, and data-related consequences if a vulnerability is successfully exploited.

- **Critical Impact:** Severe compromise of confidentiality, integrity, or availability with material business or operational consequence.
- **High Impact:** Significant unauthorized access, data exposure, or business-process abuse affecting sensitive functions or users.
- **Medium Impact:** Meaningful security weakness with constrained scope, partial exposure, or limited operational effect.
- **Low Impact:** Minor weakness with limited practical consequence or low-value exposure.

Impact	Description
Low	
Medium	
High	

Measurement of Likelihood

Likelihood reflects how feasible exploitation is in practice, considering attacker capability, required access, and environmental constraints.

- **High Likelihood:** Exploitation is straightforward and requires limited skill, access, or environmental dependency.
- **Medium Likelihood:** Exploitation is feasible but requires some knowledge, sequencing, or favorable conditions.
- **Low Likelihood:** Exploitation requires significant effort, elevated preconditions, or specialized capability.

Likelihood	Description
Low	
Medium	
High	

Overall Risk

Overall risk is derived from the intersection of impact and likelihood and is used to prioritize remediation efforts. Findings with the highest combined rating should be addressed first, especially where exploitability and business consequence are both significant.

- Low Impact + Low Likelihood = Low Risk
- High Impact + High Likelihood = Critical Risk
- **Low Impact + Low Likelihood** = Low Risk
- **High Impact + High Likelihood** = Critical Risk

Zero-risk Issues

Items categorized as zero-risk or informational are included where useful for context but should not be treated as exploitable vulnerabilities. These entries may still be valuable for hardening, visibility, or long-term security maturity planning.

Vulnerabilities

Summary

Below is a summary of the vulnerabilities discovered during the assessment, ranked in order of risk as determined:

Vulnerability	Risk
Broken Authentication: Missing Session Validation for Zendesk JWT Generation	High
Broken Access Control Allows Unauthorized User Data Access	Medium

Detailed Vulnerabilities

Broken Authentication: Missing Session Validation for Zendesk JWT Generation

Risk: High

Description:

The application's Zendesk messaging JWT generation endpoint, located at `https://swiftdigitalservices.com/ajax/zendesk_messaging_jwt.php``, is vulnerable to broken authentication. This endpoint accepts a POST request containing a base64-encoded user ID to generate a Zendesk JWT authentication token. However, the server fails to validate the user's session cookie, allowing an unauthenticated attacker to send requests without any session information and generate valid Zendesk JWT tokens for arbitrary user IDs. These tokens can then be used to access user-specific information and functionality within the Zendesk chat system.

Affected URL:

- https://swiftdigitalservices.com/ajax/zendesk_messaging_jwt.php

Impact and Likelihood:

- **Impact:** The impact of this vulnerability is high, as an attacker can generate Zendesk JWT tokens for any user. This allows for unauthorized access to user-specific data, including Personally Identifiable Information (PII), and the ability to perform actions such as initiating or participating in chats on behalf of other users. Such unauthorized access can lead to severe privacy breaches, impersonation, reputational damage, and potential regulatory non-compliance for the affected organization.
- **Likelihood:** The likelihood of exploitation is high because the vulnerability can be triggered by sending a simple POST request to the affected endpoint without requiring any prior authentication or valid session. An attacker can easily enumerate or guess user IDs, encode them, and generate valid Zendesk JWT tokens, making the attack straightforward and highly reproducible.

Steps to Reproduce:

Step 1: Identify a valid user ID within the application (e.g., by observing legitimate traffic or enumeration).

Step 2: Base64 encode the target user ID.

Step 3: Send a POST request to `https://swiftdigitalservices.com/ajax/zendesk_messaging_jwt.php`` with the encoded user ID in the request body, ensuring no session cookies are included.

Step 4: Observe that the server responds with a valid Zendesk JWT authentication token for the specified user ID.

Step 5: Utilize the generated JWT token to access Zendesk functionalities as the impersonated user.

Recommendations:

- ****Authentication and Authorization:**** Implement robust authentication and authorization checks on the ``zendesk_messaging_jwt.php`` endpoint. Ensure that only authenticated and authorized users can request JWT tokens, and only for their own user ID.
- ****Session Validation:**** Validate the user's session cookie for all requests to the JWT generation endpoint. The server must verify that the request originates from a legitimate, authenticated user session.
- ****Access Control:**** Implement strict access control mechanisms to prevent unauthorized users from generating JWT tokens for other users. This may involve mapping the authenticated user's ID to the ID used in the JWT generation request.
- ****Secure JWT Generation:**** Review the JWT generation process to ensure it adheres to best practices, including using strong cryptographic algorithms, appropriate key management, and short expiration times for tokens.

References:

- https://owasp.org/www-project-top-ten/2021/A07_2021-Identification_and_Authentication_Failures

Broken Access Control Allows Unauthorized User Data Access

Risk: Medium

Description:

The application exhibits a broken access control vulnerability where a lower-privileged user can bypass intended authorization mechanisms. By directly accessing a specific PHP endpoint and manipulating URL parameters, an authenticated user can view details of other users, including sensitive information such as usernames and passwords, despite the user interface restricting such access. This allows for unauthorized data exposure and potential account compromise.

Affected URL:

- https://www.dev.blackrockgalleries.com/auction-admin/add_admin.php?id=137&brg=kkbiv65212

Impact and Likelihood:

- **Impact:** The potential impact of this vulnerability is significant, as it can lead to unauthorized access to other user accounts within the system. Exposure of usernames and passwords can result in account takeover, privilege escalation, and further compromise of the application or associated systems. This could lead to data breaches, reputational damage, and potential regulatory non-compliance.
- **Likelihood:** The vulnerability is highly likely to be exploited as it requires only an authenticated lower-privileged user to directly access a specific endpoint with a modified parameter. No complex tools or advanced techniques are necessary, making it easily discoverable and exploitable by an attacker with basic understanding of web application functionality.

Steps to Reproduce:

Step 1: Log in to the seller admin portal with a lower-privileged user account (e.g., 'manager' role).

Step 2: Navigate directly to the URL: `https://www.dev.blackrockgalleries.com/auction-admin/add\_admin.php?id=137&brg=kkbiv65212` (or any other valid user ID in the 'id' parameter).

Step 3: Observe that the page displays the details of the user corresponding to the 'id' parameter, including their username and password, despite the logged-in user's lower privileges.

Recommendations:

- ****Implement Server-Side Access Control:**** Ensure that all requests to sensitive resources are authorized on the server-side. Before displaying or processing user data, verify that the authenticated user has the necessary permissions to access that specific resource or user ID.
- ****Enforce Least Privilege:**** Design access control policies based on the principle of least privilege, ensuring users only have access to the data and functionality strictly required for their role.
- ****Validate Input Parameters:**** Implement robust input validation for all parameters, especially those used to identify resources (e.g., 'id'). While validation helps, it should always be complemented by server-side authorization checks.
- ****Avoid Direct Object References:**** Do not expose internal object references (like database IDs) directly in URLs or forms. Consider using opaque, non-sequential identifiers or mapping user-specific data without exposing underlying IDs.

References:

- https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control

- <https://cwe.mitre.org/data/definitions/284.html>

Appendix A

The appendix content below is static template material and will be rendered into reports that use this template.